# Hazard Analysis
# Software Engineering

Team 6, Blockchainerz
Robert Lam
Nathan Hum
Aidan Lao
Keira Laskoski

Table 1: Revision History

| **Date** | **Developer(s)** | **Change** |
|---|---|---|
| October 15 | 1.0 | Nathan: Added Scope and Purpose of Hazard Anaylsis and critical assumptions |
| Date2 | Name(s) | Description of changes |
| ... | ... | ... |

# Contents

**1 Introduction** **1**

**2 Scope and Purpose of Hazard Analysis** **1**

**3 System Boundaries and Components** **2**
3.1 Components Within the System Boundary . . . . . 2
3.2 Components Outside the System Boundary . . . . . 3

**4 Critical Assumptions** **3**

**5 Failure Mode and Effect Analysis** **5**

**6 Safety and Security Requirements** **7**

**7 Roadmap** **7**

**8 Appendix — Generative AI Use Disclosure** **8**
8.1 AI Tools Used . . . . . 8
8.2 How and Where Used . . . . . 8
8.3 Verification of AI-Generated Content . . . . . 8

**9 Appendix — Reflection** **9**

[You are free to modify this template. —SS]

# 1 Introduction

[You can include your definition of what a hazard is here. —SS]

# 2 Scope and Purpose of Hazard Analysis

The purpose of the hazard analysis is to identify potential hazards within the DAIIM system, examine their causes and effects, assess their associated risks, and establish mitigation strategies to eliminate or reduce the likelihood and severity of these hazards. The analysis considers the system components and boundaries defined in Section 2, with particular emphasis on the reliability of AI inference results, the integrity and security of marketplace operations, and the fairness of participant incentives. The hazard analysis will focus on identifying hazards that may lead to the following:

- **Inference accuracy:** Incorrect, inconsistent, or unreliable aggregated predictions resulting from inaccurate model outputs, weaknesses in the aggregation algorithm, or insufficiently reliable inference providers.
- **Data and transaction integrity:** Loss, corruption, or inconsistency of inference requests, prediction results, reputation information, or transaction records, potentially resulting in incorrect outcomes or payments.
- **Security and malicious participation:** Unauthorized actions or deliberate attempts to manipulate the marketplace, including collusion between inference providers to influence aggregated predictions, reputation scores, or reward distribution.
- **System availability and reliability:** Failure to submit, process, or return inference requests due to unavailable providers, failed transactions, or disruptions affecting the application's operation.
- **Economic incentives and fairness:** Incorrect payment calculations, reward distributions, or stake handling that result in financial losses for task requesters or inference providers. The analysis also considers weaknesses in the reward and penalty mechanisms that fail to incentivize accurate predictions, allow malicious or colluding providers to benefit unfairly, or undermine the reliability and economic sustainability of the marketplace.

The analysis will consider hazards arising from the interactions between the application's components, including the off-chain backend, AI inference providers, aggregation and reputation mechanisms, and on-chain programs. External dependencies, such as blockchain network infrastructure and third-party inference services, will be considered where their failures or limitations could affect the safety, security, reliability, or intended operation of DAIIM. Hardware failures and other external events beyond the system's boundaries will otherwise remain outside the scope of the analysis.

[You should say what **loss** could be incurred because of the hazards. —SS]

# 3 System Boundaries and Components

This section divides DAIIM into its major components and identifies where the boundary of the system lies. Components inside the boundary are built, deployed, and maintained by the team, and their behaviour can be changed to mitigate hazards. Components outside the boundary are part of DAIIM's environment: DAIIM depends on them, but cannot control them, so hazards originating from them can only be detected, tolerated, or contained. The components below are based on the requirements in the SRS and the technologies listed in the Development Plan. They are preliminary and will be refined in the design documents.

## 3.1 Components Within the System Boundary

1. **Web Client.** The browser-based user interface, built with React, through which task requesters and inference providers use DAIIM. It connects to the user's wallet for authentication, lets users browse and create tasks, submit inference requests, register as providers, and view results, reputations, stakes, and rewards. Before each transaction, it shows the user the action being performed and the amount of tokens being transferred, and afterwards it shows the transaction's status and identifier. It also performs an initial check that request inputs conform to the task's input schema. *Related SRS requirements:* Accounts and Authorization, Inference Tasks, Inference Requests, Aggregation and Results, Transparency.

2. **On-Chain Programs.** The Solana programs, written in Rust, that hold DAIIM's authoritative state and all of its tokens. They are responsible for:

   - the registry of inference tasks and their parameters (minimum providers, reputation tolerance, acceptance period, maximum prediction time);
   - provider registration and the escrow of provider stakes;
   - escrow of requester payments and the lifecycle of each inference request (acceptance period, prediction phase, cancellation and refunds);
   - recording predictions, aggregating them into the final result, and updating provider reputations;
   - distributing rewards, and slashing or burning provider stakes.

   Because this component holds funds and blockchain transactions cannot be reversed, a defect here can cause direct and permanent financial loss. *Related SRS requirements:* Inference Tasks, Provider Registration and Staking, Provider Acceptance and Predictions, Aggregation and Results, Reputation and Rewards, Penalties, Transparency.

3. **Off-Chain Backend Service.** A Node.js and TypeScript service that performs the work that is impractical or unsafe to do on-chain. It monitors the on-chain programs for new inference requests and broadcasts them to the providers registered for the task, stores request input data and distributes it only to the requester and the providers that accepted the request, and deletes the input data once the request is completed or cancelled. It may also submit the transactions that move a request from one phase to the next when a deadline passes, since on-chain programs cannot act on their own, and it serves marketplace information to the Web Client. Since this service is a single point that the team operates, it must not be able to change results, payments, or reputations, which are controlled only by the on-chain programs.

*Related SRS requirements:* Inference Requests, Provider Acceptance and Predictions, Data Handling.

4. **Off-Chain Database.** A PostgreSQL database used by the backend service. It temporarily holds encrypted request input data, which must not be stored on the blockchain, as well as task information that is too large to store on-chain economically (such as problem descriptions, schemas, and references to training data) and indexed copies of on-chain records for fast browsing. The on-chain records remain the source of truth for any data that appears in both places. *Related SRS requirements:* Inference Tasks, Data Handling.

5. **Provider Interface.** The interface, such as an API or client library, through which an inference provider's model receives broadcast requests, accepts requests, retrieves input data, and submits predictions. It checks that predictions conform to the task's output schema before they are submitted. This component ends where the provider's own model begins. *Related SRS requirements:* Provider Acceptance and Predictions.

### 3.2 Components Outside the System Boundary

1. **Solana Blockchain Network.** The public Solana network, including its validators and the RPC nodes used to read state and submit transactions. DAIIM relies on it to execute the on-chain programs, store records, and provide the time used for request deadlines. It may become congested, raise fees, delay or drop transactions, or suffer outages.

2. **User Wallets.** Third-party Web3 wallets, such as browser wallet extensions, that hold users' private keys and sign transactions. DAIIM cannot recover a lost key, and cannot distinguish a compromised wallet from its legitimate owner.

3. **Inference Providers' Models and Infrastructure.** The machine learning models, computing resources, and network connections of each provider. DAIIM receives only the predictions they produce and cannot inspect the models. Providers may be unavailable, inaccurate, careless, or dishonest, and several providers may collude.

4. **Task Requesters and Their Input Data.** The people who define tasks and submit requests, and the sources of the input data they provide. DAIIM can check that inputs conform to a task's schema, but cannot verify that the data is correct, that task parameters are sensible, or that the data is not sensitive.

5. **Downstream Decisions.** The decisions that task requesters and beneficiaries, such as emergency management agencies, make using DAIIM's results. DAIIM is responsible for providing accurate results and information about their quality, but not for how the results are used.

6. **Hosting Infrastructure and Browsers.** The cloud or server infrastructure that hosts the backend service and database, and the web browsers on which the Web Client runs.

## 4 Critical Assumptions

The following assumptions describe the conditions under which the DAIIM system is expected to operate. These assumptions establish the operating context of the system and identify external

conditions on which its functionality depends. Potential failures and malicious behaviour within the system, such as inaccurate predictions, provider collusion, and manipulation of reward distribution, are not assumed to be impossible and will instead be addressed through the hazard analysis.

- The underlying blockchain network is operational and capable of processing transactions under normal operating conditions.
  - This assumption establishes the expected operating environment for on-chain marketplace operations. Temporary network outages, congestion, and failed transactions remain potential hazards that must be considered.
- Inference providers have access to the computational resources and model implementations required to execute the inference tasks they accept.
  - This assumption defines the expected capabilities of participating providers. Provider unavailability, insufficient computational resources, and failed inference requests remain potential hazards.
- A minimum number of two inference providers is available during the initial operation of the marketplace.
  - This assumption establishes that the marketplace has some initial provider participation to process inference requests and evaluate the aggregation, reputation, and reward mechanisms.
- Users have access to a modern web browser and an internet connection to interact with the application.
  - This assumption defines the minimum environment required to access the user interface. Network interruptions and browser compatibility issues remain potential causes of service disruption.

[These assumptions that are made about the software or system. You should minimize the number of assumptions that remove potential hazards. For instance, you could assume a part will never fail, but it is generally better to include this potential failure mode. —SS]

# 5 Failure Mode and Effect Analysis

Table 2: Failure Modes and Effects Analysis

| Failure | Ref. | Failure Modes | Failure Effect | Failure Causes | Recommended Actions |
|---|---|---|---|---|---|
| A required on-chain transaction does not succeed | H1.1 | RPC endpoint is unavailable | The intended on-chain state change or token transfer is delayed or not recorded. Depending on the operation, an inference request may not be submitted or broadcast, a prediction may not be recorded, a reputation update may be missed, or a token transfer or burn may fail. These failures could result in direct financial losses from missed or incorrect token transfers, indirect financial losses if outdated reputation scores affect provider rewards, or a suboptimal final output due to incorrect provider reputations. | RPC outage, network congestion, or an unavailable endpoint | Check transaction status and RPC health. Retry only after confirming that the transaction was not processed, and show the user its current status. |
| | H1.2 | The account lacks sufficient funds | | Insufficient token balance for the transfer or insufficient coin (native-tokens) balance for transaction fees | Check involved account balances and explain which balance is insufficient and the required amount; allow the user to add funds and retry. |
| | H1.3 | Wallet authorization is missing or invalid | | The user rejects the signature request or the submitted signature is invalid | Explain that authorization is required and allow the user to initiate another signature request. |
| | H1.4 | The transaction expires before confirmation | | Network or processing latency causes the transaction's validity period to expire | Check whether the transaction was processed; if not, regenerate the transaction and resend it. |
| | H1.5 | Transaction validation or execution failure. | | Missing or invalid signatures, invalid instruction data or account state, or unmet program constraints, such as insufficient permissions or an account not being authorized to perform the requested operation. | Display the failure reason when available and prompt the user to resolve the issue (such as authorizing a different account) before retrying the transaction. |
| A provider's private key is compromised | H2.1 | The private key is exposed through logs, error messages, or insecure storage | An attacker may control the provider's wallet, impersonate the provider, access provider data, or transfer or forfeit the provider's funds and stake. | The client library or provider software logs secrets, stores them insecurely, or exposes them to other local processes | Keep private keys under the provider's wallet control; do not send them to or store them in the client library. Redact secrets from logs and protect any required local credentials. |
| | H2.2 | The private key is intercepted during transmission | | Unencrypted transport, incorrect TLS configuration, or disabled certificate validation | Use correctly configured TLS for all communications; validate certificates and never transmit raw private keys through the API. |
| | H2.3 | A vulnerable or compromised client-library dependency exposes the private key | | A security flaw in a third-party software dependency allows an attacker to access or steal private keys used by the library. | Minimize the number of third-party dependencies, use audited and trusted package versions, and promptly update dependencies when security vulnerabilities are identified. |

Continued on next page

Table 2 – continued from previous page

| Failure | Ref. | Failure Mode | Failure Effect | Failure Cause | Recommended Action |
|---|---|---|---|---|---|
| A financial operation is handled incorrectly, resulting in an incorrect allocation or transfer of tokens. | H3.1 | The task requester is charged an incorrect amount | The task requester is charged more or less tokens than intended, causing direct financial losses for the task requester or task participants. | Incorrect financial calculation | Validate payment calculations and test the on-chain financial instructions against expected amounts. Before submitting a stake transaction, simulate it using available tools and verify that the expected balance changes match the actual change. |
| | H3.2 | Provider rewards are calculated or distributed incorrectly | Providers are underpaid, overpaid, or receive duplicate rewards. | Incorrect reward calculations, allocation logic, or duplicate processing | Validate reward calculations and ensure each request distributes rewards only once. |
| | H3.3 | Staked tokens are returned or burned under the wrong conditions | Providers may lose their stake incorrectly or retain tokens that should have been burned. | Incorrect handling of voluntary unregistration or forced removal of inference providers | Validate stake return and burn instructions with tests for each removal scenario. |
| The final inference result is not reasonably close to the ground truth. | H4.1 | The aggregation algorithm or reward incentives fail to favor accurate predictions | Users receive an inaccurate final inference result and may make decisions based on incorrect information. Inaccurate results may also undermine trust in the marketplace and its economic sustainability. | The aggregation method handles provider disagreement or outlying predictions poorly, or token rewards and penalties do not align provider incentives with prediction accuracy | Evaluate aggregation on tasks with known ground truth and varied provider prediction quality (see POC plan). Compare the simulated net rewards of honest providers producing low-error predictions with malicious providers. |
| | H4.2 | Malicious or low-quality providers significantly influence the aggregated result | | The aggregation and reputation mechanisms do not sufficiently reduce the influence of inaccurate or dishonest predictions | Simulate different proportions of honest and malicious providers. Compare aggregated results against known ground truth and report the observed error. Use the results to identify and communicate the provider composition thresholds under which the system is expected to meet its accuracy criteria. |
| | H4.3 | Colluding providers submit similar inaccurate predictions to manipulate the aggregation | | A coordinated group constitutes a large enough portion of the network to skew aggregation, reputation scores, or rewards, particularly when ground truth is unavailable | Simulate colluding groups of different sizes and measure their effect on result accuracy, reputation, and rewards. Document the provider proportions at which collusion can materially influence results. |

[The safety requirements in the table do not have to have the prefix SR. The most important thing is to show traceability to your SRS. You might trace to requirements you have already written, or you might need to add new requirements. —SS] [If no safety requirement can be devised, other mitigation strategies can be entered in the table, including strategies involving providing additional documentation, and/or test cases. —SS]

# 6 Safety and Security Requirements

[Newly discovered requirements. These should also be added to the SRS. (A rationale design process how and why to fake it.) —SS]

# 7 Roadmap

[Which safety requirements will be implemented as part of the capstone timeline? Which requirements will be implemented in the future? —SS]

# 8 Appendix — Generative AI Use Disclosure

This section provides an overview of how generative AI tools were used in the making of this document.

## 8.1 AI Tools Used

- Claude Opus 5.5 (Anthropic), used through Claude Code.

## 8.2 How and Where Used

Claude Opus 5.5 was used throughout this document to help ideate and draft its content. The team provided the tool with the SRS and the Development Plan, and used it to brainstorm the hazards, components, assumptions, and requirements that the document should address, and to produce first drafts of the text. In Section 3 (System Boundaries and Components), for example, it proposed a division of DAIIM into components inside and outside the system boundary, drafted the description of each component, and linked each component to the groups of functional requirements in the SRS that it is responsible for. It was also used to draft the text of this appendix.

The tool was used as an aid, not as a replacement for the team's own work. Team members were involved in every sentence of the document: each AI-assisted draft was read, discussed, and edited by the team, and ideas that did not fit the project were discarded or rewritten.

## 8.3 Verification of AI-Generated Content

Every sentence in this document was reviewed by at least one team member before it was included. AI-assisted content was checked against the SRS and the Development Plan to confirm that it describes responsibilities and behaviour that the requirements actually assign to DAIIM, that it does not introduce requirements or design decisions the team has not agreed to, and that it is consistent with the technologies the Development Plan lists. References to SRS requirements were checked by hand. Content that is still undecided, such as how request phases are advanced when deadlines pass, is marked as preliminary and will be confirmed in the design documents. The team remains responsible for the accuracy, completeness, and consistency of this document, regardless of whether material was first drafted by a team member or with the help of an AI tool.

# 9 Appendix — Reflection

[Not required for CAS 741 —SS]

The purpose of reflection questions is to give you a chance to assess your own learning and that of your group as a whole, and to find ways to improve in the future. Reflection is an important part of the learning process. Reflection is also an essential component of a successful software development process.

Reflections are most interesting and useful when they're honest, even if the stories they tell are imperfect. You will be marked based on your depth of thought and analysis, and not based on the content of the reflections themselves. Thus, for full marks we encourage you to answer openly and honestly and to avoid simply writing "what you think the evaluator wants to hear."

Please answer the following questions. Some questions can be answered on the team level, but where appropriate, each team member should write their own response:

1. What went well while writing this deliverable? One thing that went well during this deliverable was the concretization of the project that came out of defining functional requirements. Up until this point, the problem statement, goals and development plan gave us a good definition of the scope and the reason for the project, but there have been several looming questions about what actions the system will perform. I think we were able to successfully define the core functional requirements for the system, at a good level of abstraction. Our requirements are specific enough to say a lot about what the system is responsible for, while not proposing possible designs. This process allowed us to answer a lot of the questions we had discovered during earlier deliverables. Although these requirements are likely to evolve as the project continues (especially during the POC), this felt like a significant milestone and marker of progress.

2. What pain points did you experience during this deliverable, and how did you resolve them? A pain point we experienced for this deliverable is the organizational overhead that arose because of the volume of written content required. Because the SRS document and Hazard Analysis are large documents, it was often not straightforward to allocate sections for parallel development, review each other's work, and keep track of the work. We addressed these problems by assigning responsibility for each section, providing constructive feedback in GitHub pull requests, and reviewing the integrated documents together before final submission. This made it easier to work in parallel while catching gaps, overlap, and inconsistencies during review. It also made it a lot easier for each member to keep track of the work they were responsible for. We also plan to treat the documents as evolving artifacts, revisiting and refining earlier sections when later decisions clarified the system's requirements and hazards. We also established a standard of creating a GitHub issue for every major piece of work and tracking its progress on the Kanban board.

3. Which of your listed risks had your team thought of before this deliverable, and which did you think of while doing this deliverable? For the latter ones (ones you thought of while doing the Hazard Analysis), how did they come about? We had already considered inaccurate or unreliable predictions, provider unavailability, and malicious participation in our dev plan (POC plan). These are the main risks that the POC aims to prove are avoidable. The Hazard Analysis brought more risks into focus relating to the software environment, including failed or expired transactions, private-key exposure through software or dependencies, and incorrect reward or stake handling. These emerged after defining the main functional requirements and considering how each responsibility could fail.

4. Other than the risk of physical harm (some projects may not have any appreciable risks of this form), list at least 2 other types of risk in software products. Why are they important to consider? We talked about two other types of risk other than physical harm in the hazard analysis. Privacy risks arise if sensitive information is exposed to unauthorized parties. This can harm users and undermine their trust in the system. The other types of risk are legal and financial risks. Legal and financial risks can arise when transactions fail, are

duplicated, or charge an incorrect amount. Users could lose funds or face disputes, and the project could incur liability. These risks are important to consider because they directly affect our stakeholders and, if we cannot mitigate them, could threaten the project's success.